

Azure IAM & Cloud Security Notes

Metadata

- **Topic:** Explore Identity in Microsoft Entra ID (Zero Trust, identity landscape, AuthN/AuthZ, B2B/B2C, licensing)
- **Date:** 2026-08-25
- **Source Material:** Microsoft Learn — "Explore identity in Microsoft Entra ID"
- **Author/Creator:** Microsoft Learn

Executive Summary (The "So What?")

This module is the foundation everything else in IAM builds on: it defines identity as the "control plane" of modern security — the one common thread across every user, device, and app regardless of network location — and explains why Zero Trust replaced the old "trust everything inside the firewall" model. It matters because almost every real-world breach starts with a compromised identity, not a broken firewall; understanding AuthN vs. AuthZ, tokens, and governance is what lets you actually reason about *why* a Conditional Access policy or access package works the way it does, instead of just clicking through a wizard.

Core Concepts & Architectural Blueprint

- **Key Concept 1:** Identity as the Control Plane
 - *Definition:* A control plane is whatever decides how traffic/access flows. In Zero Trust, identity (not network location) is the control plane — every user, device, and app has one, so it's the one consistent checkpoint across on-prem, cloud, and SaaS.
 - *Security Risk:* If you can't verify who's asking, no other control (network segmentation, encryption, etc.) matters — identity compromise undermines everything downstream.
- **Key Concept 2:** Zero Trust Principles
 - *Definition:* Three rules — Verify Explicitly (check user identity, device health, location, risk every time), Use Least Privilege (JIT/JEA access, risk-based policies), Assume Breach (segment access, encrypt sessions, use analytics to limit blast radius).
 - *Security Risk:* Classic "castle and moat" identity trusted anyone once they were on the network — one stolen credential meant full access. Zero Trust assumes that will happen and limits the damage.
- **Key Concept 3:** Authentication (AuthN) vs. Authorization (AuthZ)
 - *Definition:* Authentication = proving who you are (sign-in, MFA, federation). Authorization = what you're allowed to do once verified (access policies, RBAC/ABAC/PBAC).
 - *Security Risk:* Confusing the two (or securing only one) leaves gaps — e.g., strong MFA (AuthN) means nothing if authorization grants everyone admin rights.
- **Key Concept 4:** Tokens (Access, Refresh, ID)
 - *Definition:* Access token = short-lived proof used to call APIs/resources. Refresh token = used to silently get a new access token without re-prompting login. ID token = used by the client app to authenticate the user (OpenID Connect). Most are JWTs (JSON Web Tokens) — signed, verifiable JSON claims.

- *Security Risk:* A stolen refresh token can be used to keep minting new access tokens long after the original sign-in — this is why token theft (e.g., via malware or adversary-in-the-middle) is such a high-value attacker target.
- **Key Concept 5: Claims-Based Identity**
 - *Definition:* A claim is a key/value pair about the user (e.g., `email=bob@contoso.com`) issued by a trusted identity provider inside a token. Apps use claims to make authorization decisions rather than looking up the user directly.
 - *Security Risk:* You only trust a claim as much as you trust its issuer — a misconfigured trust relationship (e.g., accepting tokens from an untrusted IdP) means accepting forged identity assertions.
- **Key Concept 6: Identity Lifecycle — Join / Move / Leave**
 - *Definition:* Join = new digital identity created when someone needs access. Move = access adjusted when a person changes role/department. Leave = access removed when no longer needed.
 - *Security Risk:* The classic failure mode (illustrated by the "Juan" example in the module): an employee leaves, HR never syncs with IT, the account isn't disabled — a year later the ex-employee's reused password gets phished and the dead account becomes an active attacker foothold.
- **Key Concept 7: Centralized vs. Decentralized Identity**
 - *Definition:* Centralized (e.g., Microsoft Entra ID) = one authority stores and verifies credentials. Decentralized (DIDs, per W3C standard) = users generate and own their own identifiers, anchored in blockchains/ledgers, with actual identity data staying encrypted off-chain under user control — not published on-chain.
 - *Security Risk:* Centralized systems are a single high-value target (compromise the IdP, compromise everything downstream); decentralized systems trade that risk for the complexity of key management resting on the end user.

Common Cloud Misconfigurations & Attack Vectors

- **The Flaw:** No offboarding/governance process tied to HR systems (the "Juan" scenario)
 - **Exploit Mechanism:** Ex-employee's account is never disabled. They reuse a personal password that later gets phished; because the account is still active with prior admin rights, an attacker now has a valid, unmonitored foothold that looks like legitimate access.
 - **Remediation:** Automate Join/Move/Leave lifecycle management tied to an authoritative system of record (HR), with regular access reviews and account deprovisioning.
- **The Flaw:** Relying on the classic "trust the network" model instead of Zero Trust
 - **Exploit Mechanism:** Once inside the perimeter (VPN, corporate network), a user or attacker has broad access with no further verification — one stolen credential = full lateral movement.
 - **Remediation:** Verify explicitly at every access attempt regardless of network location; segment access and encrypt sessions end-to-end (Assume Breach principle).
- **The Flaw:** Treating authentication strength as sufficient security on its own
 - **Exploit Mechanism:** Strong MFA is in place (AuthN), but authorization policy is overly permissive (e.g., broad role assignments) — an attacker who does get past MFA (e.g., via MFA fatigue/social engineering) lands in an over-privileged account.
 - **Remediation:** Pair strong authentication with least-privilege authorization (RBAC/ABAC) — don't treat AuthN as a substitute for AuthZ discipline.

Simulated Lab / Proof of Concept

1. **Objective:** Understand and query Microsoft Entra identity/token concepts using Microsoft Graph and Azure CLI.
2. **Steps Taken:**
 - Step 1: Reviewed the difference between Azure CLI and Microsoft Graph PowerShell syntax for identity administration tasks (e.g., creating a user).
 - Step 2: Compared claims in a decoded JWT header/payload structure (alg, typ, sub, name, aud) to understand what's actually inside an ID token.
 - Step 3: Mapped out which license (Entra ID P1 vs. P2) is required for advanced features like Privileged Identity Management (PIM).
3. **Reference Commands:**

Azure CLI — create a user

```
az ad user create --display-name "New User" --password "Password" --user-principal-name
NewUser@contoso.com
```

Microsoft Graph PowerShell — create a user

```
New-MgUser -DisplayName "New User" -PasswordProfile Password -UserPrincipalName
"NewUser@contoso.com" -AccountEnabled $true -MailNickName "Newuser"
```

4. **Outcome:** Confirmed that identity administration tasks (user creation, license assignment, token inspection) can be performed both through the portal and programmatically — the same operations covered conceptually in this module map directly to real CLI/Graph commands used day-to-day.

Key Vocabulary

- **Zero Trust:** Security model that assumes breach and verifies every request explicitly, regardless of network origin ("never trust, always verify").
- **Control Plane:** The component/checkpoint that determines how access flows — in Zero Trust, this is identity.
- **Identity Provider (IdP):** A system (e.g., Microsoft Entra ID) that creates, stores, and verifies digital identities and issues tokens.
- **AuthN (Authentication):** Proving who you are.
- **AuthZ (Authorization):** Determining what you're allowed to do once verified.
- **Access Token:** Short-lived token used to access protected resources/APIs.
- **Refresh Token:** Longer-lived token used to silently obtain new access tokens.
- **ID Token:** Token used by a client app to authenticate the user (OpenID Connect).
- **JWT (JSON Web Token):** A signed, self-contained JSON format used for most identity tokens.
- **Claim:** A key/value pair inside a token asserting a fact about the user (e.g., email, role).
- **OIDC (OpenID Connect):** Authentication protocol built on top of OAuth 2.0.
- **SAML:** XML-based open standard for exchanging authentication/authorization data between IdP and service provider.
- **Federation:** A trust relationship between domains/organizations allowing shared authentication.

- **RBAC / ABAC / PBAC:** Role-based / Attribute-based / Policy-based access control — different strategies for authorization decisions.
- **Microsoft Entra Tenant/Directory:** A dedicated instance of Microsoft Entra ID representing one organization.
- **B2B (Business-to-Business):** External Identities capability letting external users sign in with their own credentials to access your resources.
- **B2C (Business-to-Consumer):** Customer identity access management (CIAM) for consumer-facing apps at scale.
- **Decentralized Identifier (DID):** A W3C-standard, user-owned identifier anchored in a decentralized system (blockchain/ledger), with actual data kept off-chain.
- **Identity Lifecycle (Join/Move/Leave):** The process of creating, adjusting, and removing access as a person's relationship with an org changes.
- **Governance:** Ongoing oversight — access reviews, monitoring, updating — to keep an identity system from silently degrading (the anti-"Juan" pattern).
- **Entra ID P1/P2 License:** Premium license tiers unlocking features like Conditional Access (P1) and PIM (P2).